Information security & data protection policy 🔒

datawazi · Version 1.0 · Effective {{EFFECTIVE_DATE}} · Owner: Akif Azri, Director · Review: every 12 months, and after any incident

> ⓘ INTERNAL. How datawazi protects its own information and its clients' data. Written for a small team: everyone who works for or with datawazi (staff, contractors, freelancers) must follow it. It supports compliance with Malaysia's Personal Data Protection Act 2010 and its 2024 amendments, but **it is not legal advice**; have it reviewed when you register the company and take on your first client handling personal data.

---

1. Purpose and scope

This policy covers:

- **datawazi's own information**: finances, contracts, proposals, pricing, credentials.
- **Client information and data** we access, store or process during a project, including personal data.
- **Every device, account and tool** used for datawazi work, including personal devices.

2. Roles

Role	Who	Responsibilities
Policy owner / security lead	Director	Maintains this policy, approves tools, leads incident response
Data protection officer (DPO)	Director, until a DPO is required or appointed	PDPA questions, data subject requests, breach notification decisions
Everyone working for datawazi	Staff, contractors, freelancers	Follow this policy, complete the onboarding checklist, report incidents

Role	Who	Responsibilities
		immediately

Under the PDPA 2024 amendments, appointing a DPO may become mandatory depending on the volume and type of personal data processed. Check the Personal Data Protection Commissioner's current guidelines annually.

3. Data classification

Class	Examples	Rules
Public	Website, published case studies, info pack	No restrictions
Internal	Templates, internal checklists, playbook	datawazi people only
Confidential	Pricing, contracts, proposals, financials, client business information	Need-to-know only. Never in personal accounts or public tools
Restricted	Client **personal data**, sensitive personal data (health, religion, biometrics etc.), credentials, production data	Minimum necessary, client-approved storage only, encrypted, access logged, deleted at project end

When unsure, treat it as Restricted.

4. Client data rules (the most important section)

1. **Ask for less.** Prefer read-only access, aggregated or anonymised data, and samples. Never ask for more access than the SOW needs (see `delivery/kickoff/access-checklist.md`).
2. **Use the client's environment.** Build and store data in the **client's own cloud accounts and systems** wherever possible. Client data should not live on datawazi devices.
3. **Agreements first.** No personal data is accessed before the **NDA** and, where personal data is involved, the **Data Processing Agreement** are signed and the **PDPA checklist** is completed at kickoff.
4. **Mask outside production.** Personal fields are masked or pseudonymised in development and test environments.

5. **No copies in the wrong places.** Never put client data in email bodies, chat apps (WhatsApp, Telegram), personal cloud storage, USB drives or screenshots shared outside the project.
6. **AI tools.** Never paste client personal data or confidential client information into AI tools (ChatGPT, Claude, Gemini, Copilot etc.) unless:
   - the client has approved it in writing, **and**
   - the tool is on the approved list (section 9) with training on our data **switched off**.
7. **Cross-border.** Data stays in the location agreed in the DPA. No transfer outside Malaysia without written client approval and a valid PDPA basis.
8. **Deletion at the end.** At the end of hypercare or the retainer:
   - delete any client data held by datawazi;
   - ask the client to remove datawazi's access;
   - confirm both in writing (`delivery/kickoff/access-checklist.md`, "Removal").

5. Accounts and passwords

- **Password manager for everything** (e.g. Bitwarden or 1Password). Unique, generated passwords. No passwords in notes, spreadsheets, email or chat.
- **Multi-factor authentication (MFA) on every account that offers it**: Google, Cloudflare, GitHub, LinkedIn, Cal.com, bank, accounting software, client systems. Prefer an authenticator app or passkey over SMS.
- **Named accounts only.** Never share logins. Each person gets their own account on client systems.
- **Admin accounts** (Cloudflare, GitHub, Google, domain) are used only for admin work, with recovery codes stored in the password manager.
- **Leavers:** remove access to all datawazi and client systems on the last day (section 10).

6. Devices

Every laptop or phone used for datawazi work must have:

- ☐ full-disk encryption on (FileVault on Mac, BitLocker on Windows; on by default on modern phones);
- ☐ a screen lock after 5 minutes or less, with a strong password, PIN or biometric;
- ☐ automatic operating system and browser updates;
- ☐ built-in anti-malware enabled (XProtect / Microsoft Defender);

- ☐ "Find my device" enabled, so a lost device can be wiped;
- ☐ no shared user accounts on the device.

Public Wi-Fi: avoid it for client work, or use a phone hotspot. Never access client production systems from a shared or public computer.

7. Email, files and communication

- Business email only: hello@datawazi.com and named addresses. Client work is never done from a personal email address.
- Files live in **one approved cloud storage location** (section 9), organised per client, with sharing restricted to named people. No "anyone with the link" sharing for Confidential or Restricted files.
- **Phishing:** check the sender before opening attachments or links. Banks, Cloudflare and Google never ask for passwords by email. When unsure, verify by calling the sender.
- **Invoices and bank details:** if anyone asks to change bank details for a payment, confirm by phone using a number you already have, never one from the email.

8. Code and systems we build

- Code lives in **private repositories** under the client's or datawazi's account, never in public repos.
- **No secrets in code** (passwords, API keys, connection strings). Use the platform's secret store or key vault.
- Least-privilege service accounts; production changes go through a review or at least a written change note.
- Systems handed over include access-control documentation and logging (see the handover pack).

9. Approved tools register

Only approved tools are used for datawazi work. Add a tool only after checking where it stores data, whether it trains on customer data, and whether it supports MFA.

Tool	Used for	Data allowed	MFA
Google (Gmail, Calendar, Drive)	Email, calendar, files	Up to Confidential; Restricted only if the client approves	☐
Cloudflare	Website	Public	☐

Tool	Used for	Data allowed	MFA
	hosting, DNS, email routing		
GitHub (private repos)	Templates, website, code	Internal / Confidential (no client data)	☐
Cal.com	Booking fit checks	Contact details only	☐
LinkedIn, Instagram	Marketing	Public	☐
{{PASSWORD_MANAGER}}	Passwords, recovery codes	Restricted (credentials)	☐
{{ACCOUNTING_SOFTWARE}}	Invoices, bookkeeping	Confidential	☐
{{AI_TOOLS}} (business plan, training off)	Drafting, analysis	Public / Internal; client data only with written approval	☐

10. People: joining and leaving

Joining (staff, contractor or freelancer):

- ☐ signs an NDA / confidentiality clause before any access;
- ☐ reads this policy and confirms in writing;
- ☐ device checklist (section 6) completed;
- ☐ gets named accounts with the minimum access needed.

Leaving:

- ☐ all datawazi and client accounts disabled on the last day;
- ☐ shared passwords rotated;
- ☐ company files returned and deleted from personal devices;
- ☐ confirmation recorded.

11. Incident and data breach response

An **incident** is anything that may put datawazi or client information at risk: a lost laptop, a phishing click, a wrong email recipient, a leaked password, unexpected access, ransomware.

When	Action	Who
Immediately	Report to the security lead (Director) by phone. Don't try to hide or fix it alone	Whoever spots it
First hour	**Contain:** change passwords, revoke sessions and keys, wipe the lost device remotely, disconnect affected systems	Security lead
Within 24 hours	**Notify the affected client** if their data may be involved, as required by the DPA (default 24 hours). Share what happened, what data, and what we're doing	Director
Within 72 hours	Under the 2024 amendments, the **client (as data controller)** may need to notify the Personal Data Protection Commissioner, and affected individuals if there's significant harm. **Support the client** with the facts they need. If datawazi's *own* personal data is breached (e.g. its client contact	Director

When	Action	Who
	list), datawazi notifies the Commissioner itself where required	
Within 2 weeks	Write up the cause, the impact and what changes to prevent a repeat. Update this policy if needed	Security lead

Incident log (keep every incident, even small ones):

Date	What happened	Data / clients affected	Actions taken	Client notified?	Closed

12. Data retention

Data	Keep for	Then
Client project personal data	Only for the project; delete at the end of hypercare or the retainer	Delete and confirm in writing
Enquiries that didn't become work	Up to 2 years	Delete
Contracts, invoices, accounting records	**7 years** (Malaysian tax and company record-keeping)	Delete securely
Email	As long as useful; review yearly	Archive or delete
Backups	Follow the same periods as the data they contain	—

13. Data subject requests

If someone asks to access or correct their personal data, or to withdraw consent:

- **datawazi's own data** (enquiries, contacts): reply within **21 days**, as stated in the privacy notice.
- **Client data we process:** forward the request to the client (the data controller) within **2 working days**, and help them respond.

14. Annual review checklist

- ☐ Policy reviewed and the version date updated
- ☐ Tools register checked; unused accounts closed
- ☐ MFA confirmed on every account
- ☐ Device checklist re-confirmed by everyone
- ☐ Access to finished clients' systems removed
- ☐ PDPA guidance and DPO requirements re-checked
- ☐ Incident log reviewed for patterns

Acknowledgement: I have read and will follow this policy.
Name: _____ · Signature: _____ · Date: _____